



Security Controls in Shared Source Code Repositories

Intro



Shared source code repositories are where teams store and manage their code together using tools like Git, GitHub, or GitLab. Since multiple people can access and change the same codebase, these repositories become a major target for attackers. Securing them is important for protecting intellectual property, stopping data breaches, and keeping the software supply chain safe from tampering.

Access Control

One of the biggest security controls is restricting who can access the repository. This means using role based access control so only people who actually need access can get in, and giving them the least amount of permission needed to do their job. Harness explains that access should be based on user roles and that access logs should be reviewed regularly to catch

anything unusual. Multi factor authentication should also be required for anyone accessing the repository.

Branch Protection and Code Review

Branch protection rules are another key control. These rules make sure that code cannot be pushed straight to important branches without going through a review first. Checkmarx points out that branch protection is a fundamental control that keeps low quality or malicious code from getting into production, since every change has to be reviewed and approved before it is merged. This process helps catch mistakes and reduces the risk of one person quietly changing something they should not.

Secrets Management



A common mistake in shared repositories is hardcoding information like passwords or credentials directly into the code. Those are sensitive. Orca Security reports that a huge percentage of organizations still have plaintext secrets sitting in their repositories, which gives attackers an easy target if the repo is ever exposed. Instead, teams should use a secrets management tool such as HashiCorp Vault to store this information separately from the code.

Code Signing and Dependency Scanning



Code signing is used to confirm that a commit actually came from who it says it came from. Snyk explains that enforcing code signing on commits helps verify authenticity and stops

unauthorized changes from being accepted into the codebase. Dependency scanning is also important since a lot of vulnerabilities come from outdated or insecure third party libraries rather than the code the team wrote themselves.

Conclusion



Securing a code repository takes more than one single control. It requires a combination things. Like access restrictions, code review, and verification through code signing and dependency scanning. Together these practices protect the integrity of the codebase and reduce the risk of a security incident affecting the whole software supply chain.